

BCSE497J - Project-I

Secure Multi-Tenant Retrieval-Augmented Generation Temporal and Side-Channel Leakage Prevention

23BAI0027

Ayush Govindwar

23BCE2368

Vipin Chandran

23BKT0075

Mohit Talgotra

Under the Supervision of

Dr. Sivaranjani A

Assistant Professor Sr. Grade 1

School of Computer Science and Engineering (SCOPE)

B.Tech.

in

Computer Science and Engineering

Specialization in Artificial Intelligence and Machine Learning

School of Computer Science and Engineering



September 2026

ABSTRACT

Retrieval-Augmented Generation (RAG) systems are increasingly used in enterprise environments to provide users with access to organizational knowledge while reducing the limitations of standalone large language models. In multi-tenant environments, Role-Based Access Control (RBAC) is commonly used to restrict document retrieval according to user permissions. However, correct access filtering alone may not eliminate information leakage. Residual information can persist in vector indexes, response caches, or conversational memory after a user's access has been revoked. Additionally, users may infer the existence of restricted documents through observable retrieval metadata such as similarity scores, reranker confidence, response latency, and refusal patterns.

This project proposes a secure multi-tenant RAG framework that investigates and mitigates these two underexplored leakage channels. A synthetic enterprise knowledge base with defined tenants, roles, documents, and access policies is used to establish an access-aware RAG baseline. A temporal leakage attack harness evaluates whether previously accessible information remains retrievable after permission revocation through stale indexes, cached responses, or session memory. A side-channel probing mechanism evaluates whether restricted document existence can be inferred without the restricted content being directly exposed.

The framework introduces measurable security metrics including Leakage Magnitude, Leakage Half-Life, and Existence Inference Accuracy. Lightweight mitigation techniques, including revocation-aware cache and index invalidation, session-memory purging, retrieval metadata normalization, and response standardization, are evaluated in terms of leakage reduction, retrieval quality, and system latency. The project aims to provide a unified and reproducible approach for evaluating post-revocation and metadata-based leakage in secure enterprise RAG systems.

Keywords - Retrieval-Augmented Generation, Multi-Tenant Security, Role-Based Access Control, Temporal Leakage, Side-Channel Inference, Information Leakage, Enterprise AI.

TABLE OF CONTENTS

Sl.No	Contents	Page No.
	Abstract	
1.	INTRODUCTION	1
	1.1 Background	1
	1.2 Motivations	1
	1.3 Scope of the Project	2
2.	PROJECT DESCRIPTION AND GOALS	
	2.1 Literature Review	2
	2.2 Research Gap	7
	2.3 Objectives	8
	2.4 Problem Statement	8
	2.5 Project Plan	9
3.	TECHNICAL SPECIFICATION	
	3.1 Requirements	10
	3.1.1 Functional	10
	3.1.2 Non-Functional	10
	3.2 Feasibility Study	10
	3.2.1 Technical Feasibility	11
	3.2.2 Economic Feasibility	12
	3.2.2 Social Feasibility	12
	3.3 System Specification	12
	3.3.1 Hardware Specification	12
	3.3.2 Software Specification	13
4.	DESIGN APPROACH AND DETAILS	
	4.1 System Architecture	14
	4.2 Design	14
	4.2.1 Data Flow Diagram	15
	4.2.2 Use Case Diagram	17
5.	REFERENCES	20

1. INTRODUCTION

1.1 Background

Retrieval-Augmented Generation (RAG) has emerged as an effective approach for integrating large language models with external knowledge sources. Enterprise organizations can use RAG systems to retrieve relevant information from internal knowledge bases and provide context-aware responses to users. In multi-tenant environments, multiple users or organizational groups may share the same underlying knowledge infrastructure while having different access permissions. Role-Based Access Control (RBAC) is therefore commonly applied during retrieval to ensure that users receive only documents they are authorized to access.

However, access-controlled retrieval does not necessarily guarantee complete information confidentiality. Permission changes may not immediately propagate to vector indexes, caches, or conversational memory, potentially allowing previously authorized information to remain accessible after revocation. Furthermore, even when restricted documents are correctly filtered, observable retrieval signals such as similarity scores, reranker confidence, response latency, or refusal patterns may provide indirect evidence about the existence of protected information.

This project focuses on these two security concerns—temporal leakage and side-channel leakage—and aims to develop a measurable framework for evaluating and mitigating them in secure multi-tenant RAG systems.

1.2 Motivation

The increasing adoption of Retrieval-Augmented Generation (RAG) in enterprise environments makes the protection of confidential organizational information an important security requirement. In a multi-tenant RAG system, RBAC can restrict users from retrieving documents for which they do not have permission. However, permission filtering is only one layer of protection, and information may remain exposed through components such as vector indexes, response caches, and conversational memory even after access has been revoked.

A key motivation for this project is the absence of systematic evaluation of post-revocation leakage. Existing approaches generally focus on preventing unauthorized retrieval, while the amount of information that may remain accessible after a permission change and the duration for which such leakage persists are not adequately quantified. Similarly, retrieval metadata such as similarity scores, reranker confidence, response latency, and refusal behaviour may allow an unauthorized user to infer the existence of restricted documents without directly receiving their contents.

Therefore, this project is motivated by the need to move beyond basic access filtering and develop a unified approach for measuring, understanding, and mitigating temporal and side-channel leakage in multi-tenant RAG systems. The use of measurable security metrics

and lightweight mitigation mechanisms can help evaluate the security–performance trade-off while maintaining retrieval utility.

1.3 Scope of the Project

The scope of this project is to design, implement, and evaluate a secure multi-tenant Retrieval-Augmented Generation (RAG) testbed that addresses information leakage beyond conventional Role-Based Access Control (RBAC) filtering. The project considers a synthetic enterprise knowledge base containing multiple tenants, users, roles, documents, defined access policies, and sensitive ground-truth facts. Two pipeline modes are evaluated: a vulnerable baseline mode and a mitigated secure mode.

The baseline mode models common enterprise weaknesses such as cache lookup before authorization, flat vector retrieval, post-retrieval RBAC filtering, stale session memory, raw retrieval-metadata exposure, and distinguishable refusal responses. The mitigated mode applies ACL pre-filtering, tenant-aware retrieval, revocation-aware cache invalidation, session-memory purging, retrieval-metadata normalization, latency padding, and standardized refusal handling.

The project focuses on two primary security scenarios. First, temporal leakage is investigated by evaluating whether information that was previously accessible remains retrievable after a user's permissions are revoked. The evaluation considers stale vector-index entries, cached responses, and conversational or session memory. Second, side-channel leakage is investigated by determining whether the existence of restricted documents can be inferred from retrieval similarity scores, reranker confidence, response latency, cache-hit behaviour, or refusal-response patterns without exposing the restricted document content.

The project also covers the development of measurable security metrics, including Leakage Magnitude, Leakage Half-Life, and Existence Inference Accuracy. An attacker harness is used to perform direct, paraphrase, comparative, and timing-only probing experiments. Controlled A/B experiments compare the baseline and mitigated pipelines in terms of leakage reduction, retrieval quality, and latency overhead. Planned case studies on open-source RAG platforms may also be used to examine practical leakage scenarios such as chat-memory persistence, asynchronous deletion, workspace revocation, and metadata exposure.

The scope is limited to controlled experimental evaluation of these leakage channels in a synthetic multi-tenant RAG environment and does not attempt to solve all possible security or privacy threats associated with RAG systems.

2. PROJECT DESCRIPTION AND GOALS

2.1 Literature Review

Paper	Objective	Methodology	Pros / Cons	Findings
Permission-Aware RAG (Jeong & Lee, 2025) IEEE Access — Journal	Enforce real-time, document-level access control in RAG across heterogeneous, independently governed data sources	Permission-aware framework that interfaces directly with provider-controlled IAM systems instead of centrally merging RBAC/ABAC policies	Pros: Preserves policy autonomy; avoids the leakage risk of manual policy-merging. Cons: Focused on enforcement architecture, not on leakage after revocation	Scenario-based and large-scale evaluation confirm scalable policy enforcement while quantifying the access-level vs. answer-quality trade-off
Honeybee (2026) SIGMOD 2026 (PACMMOD)	Efficient RBAC for vector databases	Dynamic, overlapping vector-index partitions	Pros: Efficient RBAC with low latency. Cons: No confidentiality evaluation.	No confidentiality analysis after permission changes
Integrating Access Control with RAG (Chen & Taipalus, 2025) ACM SAC '25 — Conference	Ensure RAG answers are limited strictly to documents permitted by the user's access rights, in a healthcare setting	Proof-of-concept combining RAG retrieval with an access-control layer over sensitive patient records	Pros: Concrete enterprise/healthcare implementation. Cons: Proof-of-concept scope; no post-revocation or temporal leakage analysis	Shows access control can be enforced at retrieval time so unauthorized documents never reach the LLM
SAFE-CACHE (2026) SAFE-CACHE: Scientific Reports	Secure cache matching and timing	Cluster-centric caching and timing normalization	Pros: Mitigates cache and timing attacks. Cons: No RBAC lifecycle support.	Retrieval metadata and stale access state remain underexplored
PoisonedRAG (Zou et al., 2025) USENIX Security Symposium — Conference	Shows how poisoned texts corrupt RAG outputs	Crafts texts that rank highly and steer the LLM to a chosen answer	Pros: Rigorous, widely cited. Cons: Attack-only, no auth/revocation	Few poisoned texts reliably corrupt outputs in black/white-box settings
Traceback of Poisoning Attacks to RAG (Zhang et al., 2025) ACM Web Conference	Attribute poisoned passages back to their source after an attack is detected	Traceback framework applied to retrieval-poisoning incidents	Pros: Moves beyond detection into attribution/remediation. Cons: Does not address confidentiality or revocation-based leakage	Poisoned passages can be traced with high accuracy, enabling post-hoc remediation

(WWW '25) — Conference				
Unique Security and Privacy Threats of LLMs (Wang et al., 2025) ACM Computing Surveys — Journal	Comprehensive review of LLM-specific security/privacy threats across the model lifecycle	Taxonomy organized by lifecycle stage: pre-training, fine-tuning, deployment, agents	Pros: Peer-reviewed, 150+ references, broad lifecycle coverage. Cons: Survey only; not RAG-specific, no experimental framework	Identifies systemic evaluation gaps across all threat categories, including retrieval-augmented deployment
Membership Inference for RAG (Liu et al., 2025) (2026) ACM Web Conference 2025 (WWW '25) — Q1 Conference	Determine whether documents exist in a knowledge base	Mask-based membership inference using model outputs	Pros: Effective document membership inference. Cons: Uses only generated outputs as the attack channel.	Retrieval similarity, latency, and reranker metadata remain unexplored attack surfaces.
Privacy Risks and Mitigation Strategies (2025) IEEE SaTML 2026 — Conference	Protect sensitive information in RAG	Differential Privacy, Homomorphic Encryption, Secure Multi-Party Computation, secure retrieval	Pros: Comprehensive privacy-preserving techniques. Cons: Mostly conceptual with limited implementation.	Strong privacy discussion, but enterprise RBAC and temporal leakage are not analyzed.
Enterprise AI Must Enforce Participant-Aware Access Control (Bhatt et al., 2025) arXiv:2509.14608 — Preprint	Prevent leakage of confidential data to unauthorized users during LLM fine-tuning and RAG-based inference in multi-user enterprise settings	Demonstrates data exfiltration attacks exploiting the lack of access-control enforcement, then proposes deterministic fine-grained access control lists (ACLs) enforced across both fine-tuning and retrieval/generation stages	Pros: Deployed in a real production system (Microsoft Copilot); takes a strong position against probabilistic defenses. Cons: Position paper — deterministic ACL enforcement described conceptually, dynamic/misconfigured ACLs flagged only as future work	Existing defenses (prompt sanitization, output filtering, system isolation, training-level privacy) are fundamentally probabilistic and fail to reliably prevent leakage; only deterministic, participant-aware ACL enforcement offers robust protection

RAGuard: Secure Retrieval-Augmented Generation against Poisoning Attacks (Cheng, Sun, Gao et al., 2025) arXiv:2510.25025 — Preprint	Detect and remove poisoned texts injected into a RAG knowledge database to manipulate system outputs	RAGuard expands the retrieval scope to increase the proportion of clean texts, then applies chunk-wise perplexity filtering to detect abnormal variations and text-similarity filtering to flag highly similar texts	Pros: Non-parametric, detection-based defense effective against strong adaptive attacks. Cons: Attack/defense-only scope — no access-control or authorization dimension	Experiments on large-scale datasets show RAGuard is effective at detecting and mitigating poisoning attacks, including strong adaptive attacks
Agent-Assisted Side-Channel Attacks on Non-Prefix KV Cache in RAG (Sun, Liu, Ma et al., 2026) arXiv:2606.21842 — Preprint	Expose timing side-channel vulnerabilities in shared KV-cache fusion for multi-tenant RAG serving	Introduces SpliceLeak, the first end-to-end side-channel attack targeting non-prefix KV cache fusion, exploiting deterministic timing signatures (“Step-Wave”) from chunk-aware memory scheduling; proposes SpliceDefense, a two-layer defense using quantized chunk padding and constant-time boundary fusion	Pros: Uncovers a previously unaddressed class of structural vulnerabilities beyond strict-prefix assumptions. Cons: Focused narrowly on cache-timing side channels — no broader RBAC/authorization lifecycle coverage	SpliceLeak achieves a 100% extraction success rate with as few as 63 requests per token under realistic multi-tenant conditions; SpliceDefense flattens the timing signal with negligible throughput overhead
Towards Secure Retrieval-Augmented Generation: A Comprehensive Review of Threats, Defenses and Benchmarks (Mu, Hu, Li et al., 2026)	Provide the first end-to-end survey of RAG security across the full pipeline	Analyzes vulnerability mechanisms guided by the RAG workflow and systematically categorizes core threat vectors (data poisoning, adversarial attacks,	Pros: First unified end-to-end survey mapping the entire RAG pipeline rather than isolated vulnerabilities. Cons: Survey only — no novel empirical evaluation or enforcement mechanism	Systematically maps threat models, defenses, and benchmarks across the pipeline, highlighting gaps left by prior work that isolates individual vulnerabilities

arXiv:2603.21654 — Preprint		membership inference), then constructs a taxonomy of defenses from input and output perspectives, consolidating datasets, standards, and evaluation frameworks		
Securing Retrieval-Augmented Generation: A Taxonomy of Attacks, Defenses, and Future Directions (Xu, Zhang, Ge et al., 2026) arXiv:2604.08304 — Preprint	Organize RAG security literature around external knowledge access as a first-class security object	Proposes SLOT, a taxonomy along four axes: attack Surface, mirrored defense Layer, the CIA-based Objective it breaks, and the Target it pursues (from known-query to target-claim manipulation); maps attacks, defenses, remediation, and evaluation onto a six-stage knowledge-access pipeline	Pros: Rigorous, mutually-exclusive taxonomy explicitly separating RAG-specific risk from generic LLM risk; identifies concrete structural mismatches. Cons: Descriptive/organizational survey — proposes no new defense mechanism itself	Exposes two structural mismatches: defenses still detect poison as a semantic anomaly while newer attacks are fluent and corpus-fitting, and defense effort concentrates downstream while persistent harm originates upstream; confidentiality and target-claim manipulation remain under-served
Security and Privacy in Retrieval-Augmented Generation: Architectures, Threats, Defenses, and Future Directions for Building Trustworthy Systems (Palanisamy, Chalapathi,	Survey architectures, threats, and defenses for building trustworthy, privacy-preserving RAG systems	Reviews RAG system architectures alongside security/privacy threat categories and corresponding defense mechanisms, situating the discussion relative to adjacent surveys	Pros: Broad architectural framing connecting security and privacy concerns across the full RAG stack. Cons: Survey-level scope; no new experimental validation or enforcement framework	Consolidates architectural, threat, and defense perspectives to chart future directions toward trustworthy RAG system design

Hassija & Buyya, 2026) arXiv:2606.25533 — Preprint		(e.g., access- control, membership inference, and privacy-mitigation literature)		
---	--	---	--	--

2.2 Research Gap

Existing research establishes Role-Based Access Control (RBAC) as an important mechanism for restricting unauthorized document retrieval in enterprise RAG systems. However, the reviewed literature identifies several limitations in evaluating the security of access-controlled RAG after permissions change. The major research gaps addressed by this project are as follows.

1. Absence of a post-revocation leakage benchmark:
Current approaches generally assume that permission updates are immediately reflected across the RAG pipeline. There is no standard experimental benchmark for measuring how much restricted information may remain accessible through stale vector indexes, caches, or session memory after a user's access is revoked.
2. Retrieval metadata as an underexplored leakage channel:
Existing membership-inference research primarily investigates generated model outputs. In contrast, retrieval-level signals such as similarity scores, reranker confidence, response latency, and refusal patterns have not been systematically evaluated as black-box channels for inferring the existence of restricted documents.
3. Lack of measurable security metrics:
Existing RAG benchmarks do not adequately quantify the magnitude of information that leaks, how long leakage persists following revocation, or how accurately an unauthorized user can infer the existence of restricted documents. This creates a need for measurable metrics such as Leakage Magnitude, Leakage Half-Life, and Existence Inference Accuracy.
4. Fragmented security defenses:
Access control, cache security, timing mitigation, and retrieval performance are generally studied as separate concerns rather than as components of a unified multi-tenant RAG security framework. This makes it difficult to evaluate the overall security–performance trade-off of combined defenses.

Therefore, the identified research gap is the absence of a unified framework for measuring and mitigating both temporal leakage and metadata-based side-channel inference in multi-tenant RAG systems while preserving retrieval quality and system performance.

2.3 Objectives

The objectives of the proposed project are:

1. To develop a secure multi-tenant Retrieval-Augmented Generation (RAG) framework with Role-Based Access Control (RBAC) for access-aware document retrieval.
2. To quantify temporal leakage occurring after access revocation by evaluating the persistence of restricted information across vector indexes, caches, and conversational memory.
3. To evaluate side-channel inference by analyzing similarity scores, reranker confidence, response latency, and refusal patterns as potential indicators of restricted-document existence.
4. To implement lightweight mitigation strategies including revocation-aware invalidation, memory purging, and metadata normalization to reduce information leakage.
5. To measure leakage using defined security metrics, namely Leakage Magnitude, Leakage Half-Life, and Existence Inference Accuracy.
6. To evaluate the security–performance trade-off by comparing leakage reduction with retrieval quality and system latency.
7. To validate the proposed framework in a controlled laboratory environment, progressing from the current TRL 2–3 research concept toward the targeted TRL 4 prototype validation.

2.4 Problem Statement

Enterprise Retrieval-Augmented Generation (RAG) systems commonly use Role-Based Access Control (RBAC) to prevent unauthorized users from retrieving restricted documents. However, RBAC filtering alone does not guarantee complete information confidentiality in a multi-tenant environment. After a user's permission is revoked, previously accessible information may persist in stale vector indexes, caches, or conversational memory, resulting in temporal leakage. At the same time, even when restricted documents are correctly filtered, observable retrieval signals such as similarity scores, reranker confidence, response latency, and refusal patterns may enable unauthorized users to infer the existence of restricted documents, resulting in side-channel leakage.

The problem addressed by this project is therefore the lack of a unified and measurable approach for detecting and mitigating temporal and side-channel information leakage in access-controlled multi-tenant RAG systems. Existing approaches do not adequately quantify how much information remains accessible after permission revocation, how long such leakage persists, or how accurately restricted-document existence can be inferred through retrieval metadata. The project aims to address these limitations while preserving retrieval quality and system performance.

2.5 Project Plan

Secure Multi-Tenant RAG — Leakage Testbed: Project Timeline

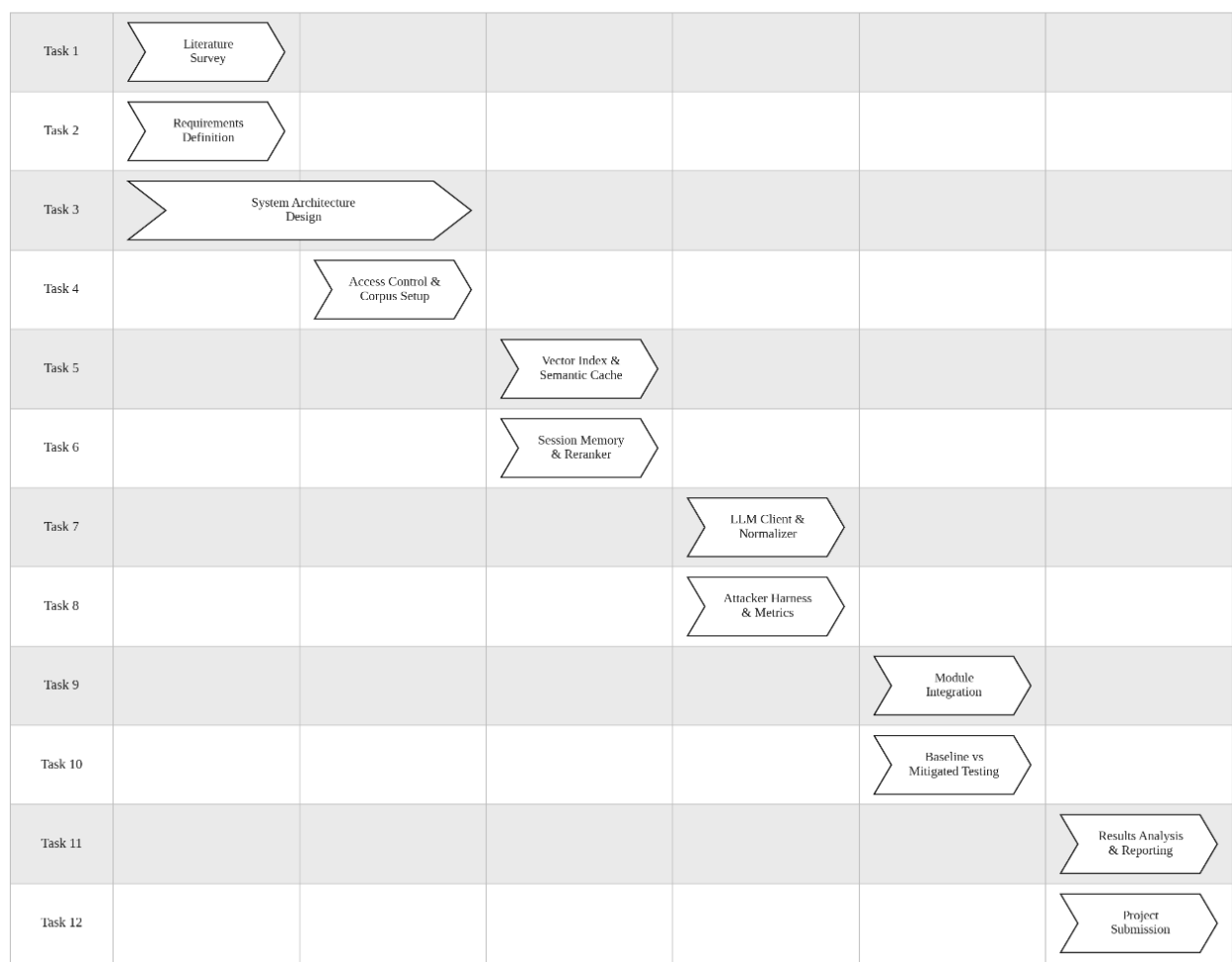


Fig. 1. Gantt chart

3. TECHNICAL SPECIFICATION

3.1 Requirements

The technical requirements define the functional capabilities and quality attributes necessary for implementing and evaluating the proposed secure multi-tenant RAG framework. The requirements are derived from the project's stated objectives of evaluating temporal leakage, side-channel inference, and the effectiveness of lightweight mitigation mechanisms.

3.1.1 *Functional*

- **Multi-Tenant Knowledge Base:** The system shall support multiple tenants and maintain a knowledge base containing documents associated with different tenants, users, roles, and access policies.
- **Role-Based Access Control:** The system shall implement RBAC-based and ACL-based retrieval controls to ensure that users can retrieve only documents permitted by their assigned access policies.
- **Access Revocation and Event Notification:** The system shall support changes to user permissions and access-revocation events. Revocation events shall notify relevant components such as the semantic cache, session memory, and vector retrieval layer.
- **Vulnerable Baseline Pipeline:** The system shall provide a baseline RAG pipeline that models common enterprise leakage mechanisms, including cache lookup before authorization, flat vector retrieval, post-retrieval RBAC filtering, stale session memory, raw metadata exposure, and distinguishable refusal responses.
- **Mitigated Secure Pipeline:** The system shall provide a mitigated RAG pipeline that implements ACL pre-filtering, tenant-aware retrieval, revocation-aware cache invalidation, session-memory purging, retrieval-metadata normalization, latency padding, and standardized refusal handling.
- **Temporal Leakage Evaluation:** The system shall evaluate whether previously accessible information remains retrievable after access revocation through stale retrieval artifacts such as vector indexes, semantic caches, or conversational memory.
- **Side-Channel Evaluation:** The system shall evaluate whether the existence of restricted documents can be inferred from observable signals such as similarity scores, reranker confidence, response latency, cache-hit behaviour, and refusal patterns.
- **Sensitive Ground-Truth Facts:** The system shall use synthetic sensitive facts or canary information associated with restricted documents to measure whether confidential content is leaked after access revocation.
- **Attack Simulation:** The system shall provide controlled probing scenarios for evaluating post-revocation retrieval and restricted-document existence inference using direct, paraphrase, comparative, and timing-only probes.
- **Leakage Measurement:** The system shall measure temporal and side-channel leakage using the defined metrics: Leakage Magnitude, Leakage Half-Life, and Existence Inference Accuracy.
- **Experimental Comparison and Telemetry:** The system shall enable controlled comparison of the baseline and mitigated pipelines and shall record structured telemetry such as query details, authorization outcomes, cache status, retrieved document identifiers, scores, latency, refusal behaviour, and leakage evidence.

- **Planned Case-Study Support:** The framework shall support planned empirical evaluation on open-source RAG platforms to examine practical leakage scenarios such as chat-memory persistence, asynchronous deletion, workspace revocation, and metadata exposure.

3.1.2 *Non-Functional*

The non-functional requirements define the quality, security, and performance characteristics expected from the proposed secure multi-tenant RAG framework.

- **Security:** The system should enforce access-controlled retrieval and prevent unauthorized users from directly accessing restricted documents. The framework should also support evaluation of temporal and side-channel leakage.
- **Confidentiality:** Restricted document content should not be exposed to unauthorized users during the retrieval and generation process. The system should also evaluate indirect information disclosure through retrieval metadata.
- **Performance:** The RAG system should provide responses with acceptable latency while enabling measurement of response-time variations that may act as potential side-channel signals.
- **Retrieval Quality:** Access-control mechanisms and security evaluation should preserve the relevance and quality of retrieved information for authorized users.
- **Scalability:** The framework should be capable of supporting multiple tenants, users, roles, and documents within a shared RAG environment.
- **Reliability:** The system should produce consistent retrieval and access-control behaviour during repeated experiments and controlled permission changes.
- **Maintainability:** The framework should use modular components so that retrieval, access control, leakage evaluation, and future mitigation mechanisms can be independently developed and evaluated.
- **Reproducibility:** The experimental framework should provide controlled configurations and measurable metrics so that temporal leakage and side-channel inference experiments can be repeated and compared.
- **Extensibility:** The architecture should allow future integration of proposed mitigation techniques, including revocation-aware invalidation, memory purging, and metadata normalization, without requiring major changes to the baseline RAG architecture.
- **Observability:** The system should capture structured telemetry and logs to support analysis of leakage surfaces, authorization decisions, cache behaviour, latency patterns, and mitigation effectiveness.
- **Ethical Compliance:** Experiments should use synthetic data and controlled environments. If real-world platforms are evaluated, responsible disclosure practices should be followed for any confirmed vulnerabilities.

3.2 Feasibility Study

The feasibility study evaluates whether the proposed secure multi-tenant RAG framework can be developed and evaluated using the available technological resources, financial requirements, and user-oriented considerations.

3.2.1 *Technical Feasibility*

- **Technology Availability:** The project can be developed using existing RAG, vector retrieval, access-control, and large language model technologies. These technologies provide the required foundation for constructing the baseline multi-tenant RAG environment.
- **Development Expertise:** The project requires knowledge of Retrieval-Augmented Generation, information retrieval, access control, cybersecurity, and experimental evaluation. The identified research objectives and threat models provide a clear technical direction for implementation.
- **Infrastructure:** The project requires sufficient computational resources to construct the RAG prototype, maintain the synthetic enterprise knowledge base, execute controlled attack scenarios, and collect retrieval and response metadata.
- **Experimental Environment:** A controlled multi-tenant environment can be created with defined tenants, roles, documents, and access policies. This makes it technically feasible to reproduce access-revocation and restricted-document inference scenarios.
- **Future Extensibility:** The proposed architecture can be extended in later stages to incorporate mitigation mechanisms such as revocation-aware invalidation, memory purging, and metadata normalization. These are part of the planned development and evaluation rather than the current implementation.

3.2.2 Economic Feasibility

The project is economically feasible because it can be developed primarily using software frameworks, development tools, and research resources that are available at low or no licensing cost. A synthetic knowledge base can also be used for experimentation, reducing the requirement for expensive proprietary enterprise datasets.

The project does not require specialized physical infrastructure beyond standard computing resources suitable for developing and testing the RAG prototype. Therefore, the expected development and experimentation costs are relatively low compared with the potential value of evaluating information-leakage risks in enterprise AI systems.

3.2.3 Social Feasibility

The project has positive social and organizational relevance because secure enterprise AI systems must protect confidential information while providing authorized users with useful knowledge. Preventing unauthorized information disclosure can improve trust in AI-assisted enterprise applications.

The framework is intended for controlled security evaluation and does not require exposing real confidential organizational data. Using a synthetic multi-tenant knowledge base also reduces privacy concerns during experimentation. The project's focus on secure digital governance and reliable AI infrastructure aligns with SDG 9 and SDG 16 identified in the project review.

3.3 System Specification

3.3.1 Hardware Specification

- **Processor:** 64-bit quad-core CPU or better, such as Intel Core i5 / AMD Ryzen 5.
- **Memory (RAM):** 8 GB minimum; 16 GB recommended for embedding and reranking models.

- **Storage:** SSD with at least 10 GB available for the repository, virtual environment, ChromaDB files, cached models, and experiment results.
- **Graphics Processing Unit (GPU):** Optional. An NVIDIA GPU with at least 4 GB VRAM and CUDA support is recommended for faster transformer processing. CPU execution is supported.
- **Monitor:** 1366×768 minimum; 1920×1080 recommended for development and experiment analysis.

3.3.2 Software Specification

- **Operating System:** Windows 10/11, Linux, or macOS. The current repository workspace is Windows.
- **Programming Languages:** Python 3.13, with YAML, JSON, CSV, and Markdown configuration/data formats.
- **Development Environment:** Visual Studio Code with virtual environment using UV
- **Libraries and Frameworks:**
 - ChromaDB for persistent vector storage
 - Sentence Transformers for embeddings and cross-encoder reranking
 - NumPy and Pandas for numerical processing and analysis
 - PyYAML for corpus metadata
 - python-dotenv for environment configuration
 - Groq, OpenAI, and Google GenAI SDKs for optional LLM providers
- **Database:** Persistent local ChromaDB vector database stored in `.chroma` and `.chroma_full`. RBAC, cache, and session-memory data are primarily maintained in memory.
- **Security Tools:**
 - Role-Based Access Control (RBAC)
 - Tenant and document-level ACL filtering
 - Revocation event handling
 - Secure semantic-cache eviction
 - Session-memory purging after revocation
 - Similarity-score and confidence-score normalization
 - Latency jitter and standardized refusal responses
 - Black-box attacker probing and leakage metrics such as LM, LH, and EIA

4. DESIGN APPROACH AND DETAILS

4.1 System Architecture

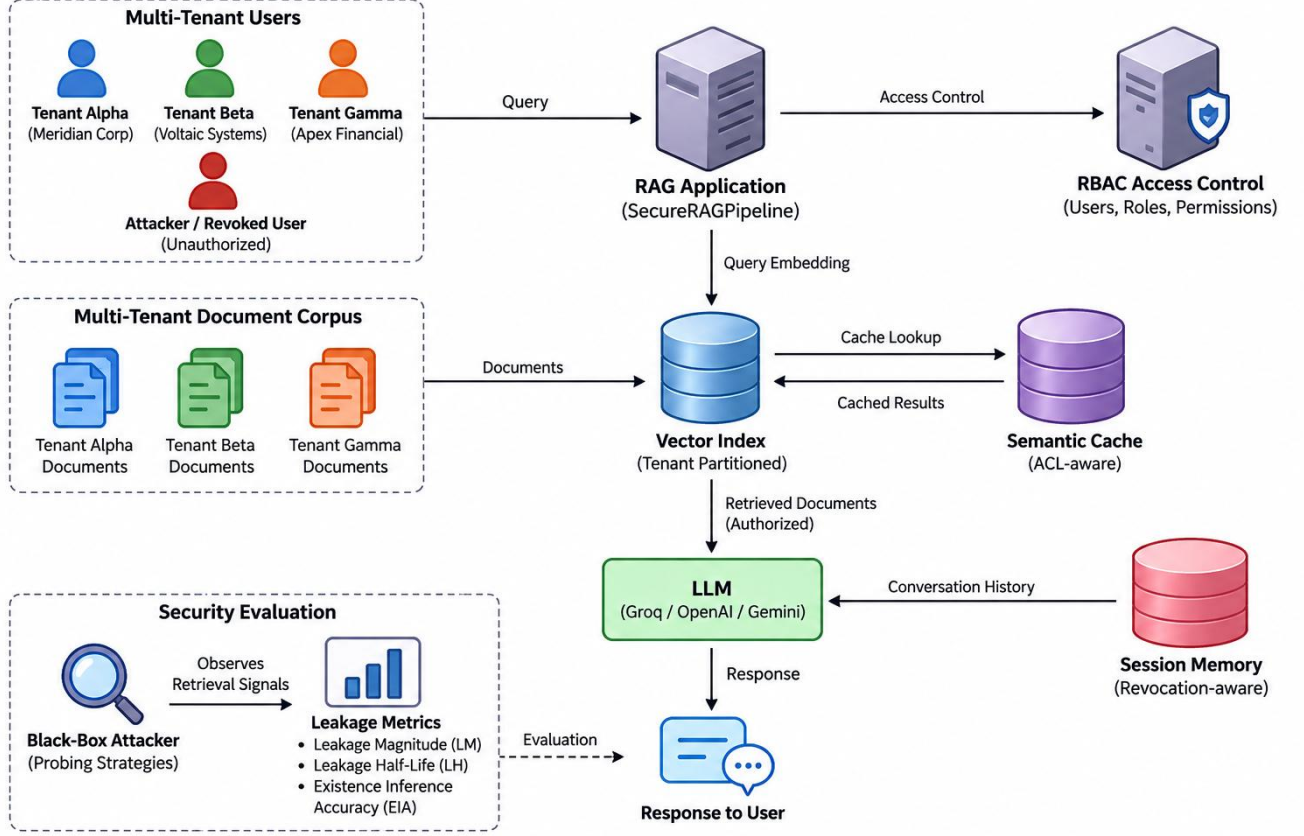


Fig. 2. System Architecture

The proposed system follows a secure multi-tenant Retrieval-Augmented Generation (RAG) architecture in which multiple users and tenants interact with a shared enterprise knowledge base while access to information is controlled through Role-Based Access Control (RBAC).

The architecture consists of several logical components. Users first submit queries to the RAG application. The query is processed and forwarded to the retrieval layer, where relevant documents are identified from the vector-based knowledge repository. Before retrieved information is provided to the language model, the RBAC mechanism evaluates the user's tenant, role, and associated access permissions and filters unauthorized documents.

The system also includes components representing the potential leakage surfaces investigated in this project: vector indexes, response caches, and conversational/session memory. These components are examined during access-revocation experiments to determine whether previously authorized information remains accessible after permissions are changed.

In parallel, the framework collects observable retrieval and response signals, including similarity scores, reranker confidence, response latency, and refusal behaviour. These signals

are used by the side-channel evaluation component to determine whether an unauthorized user can infer the existence of restricted documents without receiving their actual content.

The evaluation layer measures the identified security risks using Leakage Magnitude, Leakage Half-Life, and Existence Inference Accuracy. The resulting measurements are used to assess the security of the baseline access-controlled RAG system and provide a basis for evaluating the mitigation strategies planned for subsequent development.

4.2 Design

4.2.1 Data Flow Diagram

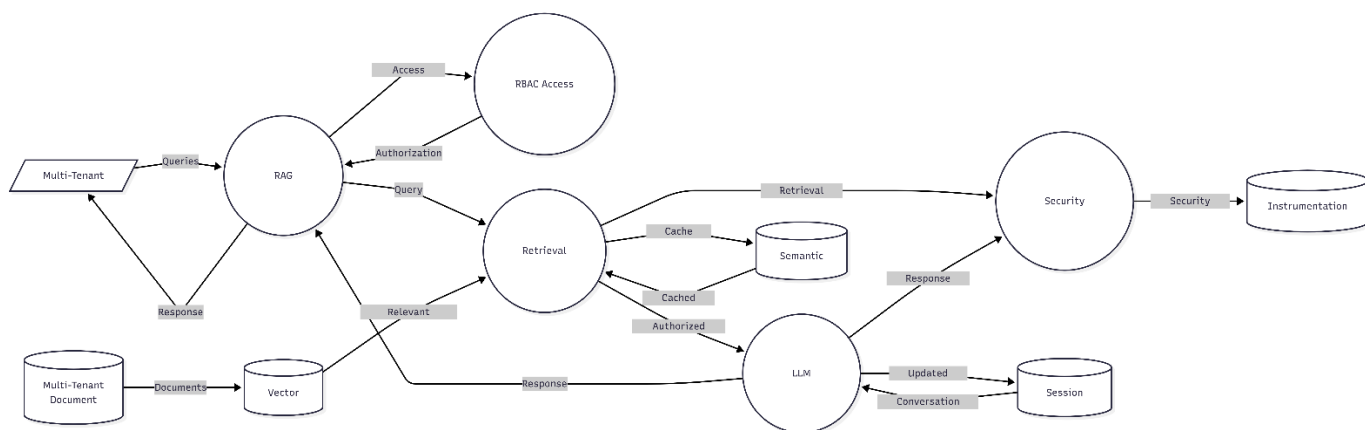


Fig. 3. Data Flow Diagram

The diagram represents the overall data flow of the Secure Multi-Tenant Retrieval-Augmented Generation (RAG) system. The system combines multi-tenant document retrieval, role-based access control (RBAC), semantic caching, LLM-based response generation, session memory, and a security evaluation framework for measuring information leakage.

The system begins with Multi-Tenant Users, who submit natural-language queries to the RAG component. The RAG application processes the query and interacts with the RBAC Access component to verify whether the user is authorized to access the requested information. The project uses tenant assignment, role-based grants, and document-level grants to determine access permissions.

The query is then passed to the Retrieval component. The system converts the query into an embedding and uses it for semantic retrieval. The Multi-Tenant Document repository provides the documents used to construct the Vector Index. The vector index performs similarity-based retrieval and returns relevant document candidates. In the mitigated implementation, retrieval is restricted to the requesting user's tenant and authorized document set before similarity computation.

The Semantic Cache provides a second retrieval path. Previously processed queries and results can be stored in the cache and retrieved when a sufficiently similar query is received. In the

baseline implementation, cache lookup does not perform an RBAC check, whereas the mitigated implementation verifies tenant isolation and current access permissions before returning cached results. Cache entries affected by access revocation can also be invalidated immediately.

After retrieval and authorization, the relevant authorized information is passed to the LLM for response generation. The LLM receives the authorized retrieved context along with applicable conversation history from the Session component. The generated response is returned through the RAG application to the user. The project supports multiple LLM backends, including Groq, OpenAI, Gemini, and a deterministic stub backend.

The Session component stores conversation history that can be used as context for subsequent queries. Session memory is particularly important to the project's temporal-leakage threat model because previously generated conversations may contain references to documents whose access has subsequently been revoked. In the mitigated implementation, session memory tracks referenced documents and purges affected conversation turns following revocation.

The Security component represents the project's security evaluation framework. It evaluates the system for the two principal leakage channels investigated in the project: temporal leakage and side-channel leakage. Temporal leakage examines whether restricted information remains accessible after permission revocation through stale vector-index entries, cached responses, or session memory. Side-channel leakage examines whether the existence of restricted information can be inferred from observable signals such as similarity scores, reranker confidence, response latency, and refusal behavior.

The results of system activity are recorded through Instrumentation. The actual implementation records information such as query details, tenant and user information, similarity scores, reranker scores, latency, retrieved and accessible document IDs, refusal information, cache hits, and experimental strategy. These observations support the subsequent security analysis.

Overall, the data flow can be summarized as:

Multi-Tenant User → RAG → RBAC Access → Retrieval → Authorized Context → LLM → RAG → User

with supporting data flows through the Multi-Tenant Document Repository, Vector Index, Semantic Cache, and Session Memory, while system observations are passed to the Security and Instrumentation components for leakage evaluation.

The diagram therefore captures the project's central idea: providing access-controlled RAG retrieval while evaluating and mitigating information leakage that may persist after access revocation or be inferred indirectly through system metadata and response behavior. The project specifically evaluates these risks using Leakage Magnitude (LM), Leakage Half-Life (LH), and Existence Inference Accuracy (EIA).

4.2.2 Use Case Diagram

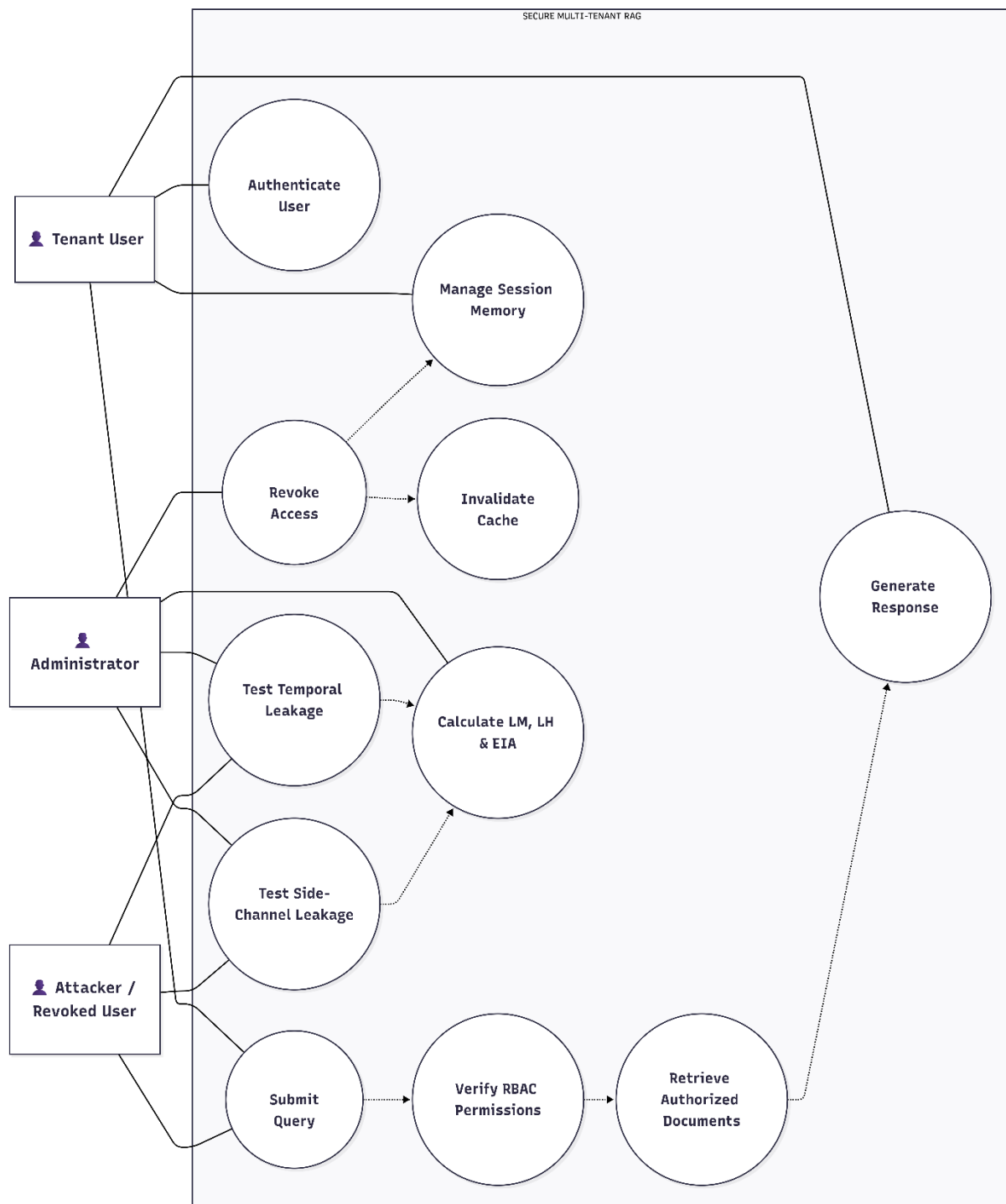


Fig. 4. Use Case Diagram

The Use Case Diagram illustrates the major interactions between the Secure Multi-Tenant RAG System and its three represented actors: Tenant User, Administrator, and Attacker/Revoked User. The system is designed to provide access-controlled retrieval while evaluating and mitigating information leakage caused by stale retrieval artifacts and observable side-channel signals.

- **Tenant User:** The Tenant User represents an authorized user belonging to a particular tenant. The primary interaction of the tenant user with the system is to submit a query and receive a generated response. When a query is submitted, the system verifies the user's current access permissions through the RBAC mechanism before retrieving authorized documents. The project supports tenant-level, role-based, and document-level access control. Therefore, retrieval is restricted according to the user's current authorization and tenant boundaries. The diagram also represents authentication and session memory. In the actual implementation, however, session memory is an internal part of the RAG pipeline rather than a feature that users directly operate. The system maintains conversation history and uses it as context during response generation.
- **Administrator:** The Administrator represents the actor responsible for managing access-related operations and overseeing the security evaluation environment. A key operation is Revoke Access. The project supports three types of revocation:
 - Single-document revocation – removes access to a particular document for a user.
 - Role revocation – removes the documents associated with a particular role.
 - User offboarding – removes the user's access to all associated documents and roles.

When revocation occurs in the mitigated mode, a revocation event is propagated to the relevant components, including the vector index, semantic cache, and session memory. This allows stale information to be invalidated or removed following an access change.

- **Attacker / Revoked User:** The Attacker / Revoked User represents an unauthorized user or a user whose access to previously available information has been revoked. This actor is used to model attempts to obtain restricted information through queries and probing. The project evaluates two principal attack categories:
 - **Temporal Leakage:** determining whether previously accessible information remains retrievable after access has been revoked through stale vector-index entries, cached responses, or session/conversation memory.
 - **Side-Channel Leakage:** determining whether the existence of restricted documents can be inferred from observable signals such as similarity scores, reranker confidence, response latency, or refusal behavior.

The actual implementation uses an attacker harness with four probing strategies and a standard probe suite to perform these experiments.

- **Query Processing and Authorized Retrieval:** The central RAG workflow begins when a user submits a query. The query is converted into an embedding and used for semantic cache lookup and vector retrieval. The system then applies access control to determine which documents the user is authorized to access. In the mitigated implementation, retrieval is pre-filtered using the user's tenant and authorized document set, rather than retrieving unrestricted candidates first and filtering them afterward. The authorized documents are then used as context for the LLM Generation stage, which

produces the response returned to the user. Thus, the main functional flow represented by the diagram is:

Submit Query → Verify RBAC Permissions → Retrieve Authorized Documents → Generate Response

- **Cache Invalidation and Session Memory:** The Revoke Access → Invalidate Cache relationship represents the project's revocation-aware protection against temporal leakage. In the mitigated implementation, the semantic cache performs tenant validation and live RBAC verification and has an invalidation hook that immediately removes affected cache entries following revocation. Similarly, the secure session-memory component tracks document references associated with conversation turns and purges affected turns when access is revoked. For user offboarding, all relevant sessions can be cleared.
- **Security Metrics:** The security evaluation produces three principal metrics:
 - Leakage Magnitude (LM): measures the amount of restricted information recovered.
 - Leakage Half-Life (LH): measures how long leakage persists following access revocation.
 - Existence Inference Accuracy (EIA): measures how accurately an attacker can infer whether restricted information exists from observable signals.

The project uses LM and LH primarily for evaluating temporal leakage, while EIA evaluates side-channel-based existence inference.

5. REFERENCES

1. S. S. Bhatt, T. Rajore, K. Aggarwal, et al., “Enterprise AI Must Enforce Participant-Aware Access Control,” arXiv:2509.14608, 2025.
2. H. Zhong, M. Lentz, N. Narodytska, A. Szekeres, and K. Rong, “Honeybee: Efficient Role-Based Access Control for Vector Databases via Dynamic Partitioning,” *PACM SIGMOD*, 2026.
3. Z. Cheng, J. Sun, A. Gao, et al., “Secure Retrieval-Augmented Generation against Poisoning Attacks,” 2025.
4. M. Afiffy, M. W. Fakhr, and F. A. Maghraby, “Enhancing Adversarial Resilience in Semantic Caching for Secure RAG Systems,” *Scientific Reports*, 2026.
5. Jeong, J., & Lee, S. (2025). Permission-aware RAG: Identity and access management (IAM)-based access filtering in multi-resource environments. *IEEE Access*, 13, 192819–192835.
6. Chen, B., Tackman, J., Setälä, M., Poranen, T., & Zhang, Z. (2025). Integrating access control with retrieval-augmented generation: A proof of concept for managing sensitive patient profiles. In *Proceedings of the 40th ACM/SIGAPP Symposium on Applied Computing (SAC '25)* (pp. 915–919). ACM.
7. Liu, M., Zhang, S., & Long, C. (2025). Mask-based membership inference attacks for retrieval-augmented generation. In *Proceedings of the ACM Web Conference 2025 (WWW '25)* (pp. 2894–2907). ACM.
8. Bodea, A.-E., Meisenbacher, S., Klymenko, A., & Matthes, F. (2026). SoK: Privacy risks and mitigations in retrieval-augmented generation systems. *IEEE Conference on Secure and Trustworthy Machine Learning (SaTML 2026)*.
9. H. Sun, S. Liu, S. Ma, et al., “Agent-Assisted Side-Channel Attacks on Non-Prefix KV Cache in RAG,” arXiv:2606.21842, 2026.
10. Y. Mu, H. Hu, F. Li, et al., “Towards Secure Retrieval-Augmented Generation: A Comprehensive Review of Threats, Defenses and Benchmarks,” arXiv:2603.21654, 2026.
11. Y. Xu, M. Zhang, Z. Ge, et al., “Securing Retrieval-Augmented Generation: A Taxonomy of Attacks, Defenses, and Future Directions,” arXiv:2604.08304, 2026.
12. B. Palanisamy, G. S. S. Chalapathi, V. Hassija, and R. Buyya, “Security and Privacy in Retrieval-Augmented Generation,” arXiv:2606.25533, 2026.
13. Zou, W., Geng, R., Wang, B., & Jia, J. (2025). PoisonedRAG: Knowledge corruption attacks to retrieval-augmented generation of large language models. In *Proceedings of the 34th USENIX Security Symposium*.
14. Zhang, B., Xin, H., Fang, M., Liu, Z., Yi, B., Li, T., & Liu, Z. (2025). Traceback of poisoning attacks to retrieval-augmented generation. In *Proceedings of the ACM Web Conference 2025 (WWW '25)* (pp. 2085–2097). ACM.

15. Wang, S., Zhu, T., Liu, B., Ding, M., Ye, D., & Zhou, W. (2025). Unique security and privacy threats of large language models: A comprehensive survey. *ACM Computing Surveys*, 58(4).